Católica
Universidade Católica de Brasília

Riscos de Segurança e Conformidade

Consultoria 02

Professor: Alexandre Silva

Arthur Barbosa, Eduardo Daga, Fernando Hatabe, Gabriel Caetano, Gabriel Sales e João Paulo

O CONCEITO

A Evolução para o DevSecOps

A antecipação como regra. O **Security by Design** integra a segurança desde a primeira linha de código.



SAST

Caixa Branca

Busca falhas estáticas antes da compilação.



DAST

Caixa Preta

Simula ataques externos em tempo de execução.



SBOM

Lista de Materiais

Inventário de dependências para mitigar ameaças open-source.

Privacy by Design

A LGPD transformou a privacidade de um diferencial técnico para uma exigência legal de sobrevivência corporativa.

1

Ativos Críticos

Dados pessoais exigem governança total no fluxo de valor.

2

Operação às Cegas

CI/CD sem validações de SAST/DAST e sem SBOM claro.

3

Violação Federal

Vazamento resulta em multas pesadas e danos de reputação.

CASO DE MERCADO

O Desastre da Equifax (2017)

A Falha (Sem SBOM)

Vulnerabilidade ignorada em componente antigo (Apache Struts).

Falta de Governança

Ausência de testes ativos e patch management deficiente.

O Prejuízo

US$ 1,4 bilhão em acordos legais e reputação destruída.

147M

Registros pessoais vazados por falta de rastreabilidade.

Governança na Esteira de Software

A Prática

Quality Gates Automatizados no CI/CD

Implementação de travas na esteira. Se o SAST detecta vulnerabilidade Alta/Crítica, o deploy é bloqueado automaticamente.

O Indicador

MTTR Focado em Segurança

Mede o tempo exato para engenharia desenvolver, testar e implantar o patch corretivo em produção.

"Sua diretoria prefere atrasar o lançamento milionário da Black Friday ou aprovar o deploy ignorando o Quality Gate, arriscando a exposição penal dos dados dos clientes?"

REFERÊNCIAS BIBLIOGRÁFICAS

- ISACA. COBIT 2019 Framework. 2018.
- FORSGREN, N. et al. Accelerate: The Science of Lean Software. 2018.
- PRESSMAN, R. S.; MAXIM, B. R. Engenharia de Software. 9ª ed. 2021.
- ISO/IEC 25010:2011.
- ABNT NBR ISO/IEC 38500 - Governança de TI.
- BRASIL. Lei nº 13.709/2018 (Lei Geral de Proteção de Dados - LGPD).
- SAMPAIO, Cleuton. Qualidade de Software na Prática. 2020.
- SOMMERVILLE, I. Engenharia de Software. 10ª ed. 2019.